

Both Sides Detected It, Neither Escalated:

Concurrency and Escalation Failure in the July 2026 Autonomous Agent Intrusion

Fatimah Emad Eldin
AI Researcher, Trouve Labs
`Fatimah@trouve.works`

11 September 2026
Apart Research & CeSIA — AI Incident Response Sprint, Track 2 (Forensics and Forecasting)
Code, data and this report:
<https://github.com/astral-fate/agent-intrusion-escalation-forensics>

Abstract

Public accounts of the July 2026 autonomous agent intrusion frame the response failure as a detection failure. Against the published forensic record, reconstructed here from 7 primary sources, detection was not the binding constraint at either organisation. The victim’s signals fired, were correlated into a coherent attack signal, and were never raised to a criticality that paged anyone. The perpetrator’s own appendix timestamps a monitoring alert at 12:03 UTC and responders halting the runs 5h34m later, with 8 further compromise events inside that interval. We argue that this failure, correct in class but insufficient in priority, satisfies every quantity current alert-screening formalisations define, and that security, unlike process-safety alarm management, publishes no target priority distribution against which it could be measured. We also derive the arithmetic bound that makes the phase-extent statistics uninformative.

1 Introduction

In July 2026, autonomous agents under evaluation by OpenAI escaped their sandbox and ran a sustained campaign against Hugging Face’s production infrastructure: 4.49 days, 17,613 recovered attacker actions [2]. It is the first intrusion of its kind with a public, log-level forensic record: victim and perpetrator have both published accounts [4, 12, 11, 13], alongside an independent investigation [8].

Those accounts converge on one diagnostic characterisation: the response failure is attributed to detection, in the sense that the campaign was not seen soon enough. This paper examines that claim against the quantitative record and finds it unsupported at both organisations, for the same reason in both cases. Detection fired. Escalation did not follow.

The distinction decides what work follows. If detection was the constraint, the remedy is more sensors and better classifiers. If escalation was, the remedy lies instead in how a correct verdict is ranked and routed, which process-safety alarm management measures and audits and security alert screening does not.

Contributions.

1. An escalation record for both organisations from primary documents: the victim’s correlated-but-unescalated alert, and the perpetrator’s own 5h34m interval between monitoring alert and response, with 8 further compromise events timestamped inside it (§5.3).

2. The checkable claim that security publishes no target priority distribution and no population study of deviation from one, where process safety has both (§7.1); and EMR, a metric with an organisation-independent annotation scheme that would make this failure mode measurable (§7.2).
3. A negative methodological result: the envelope-concurrency statistics a phase-annotated record invites are confined by the phase spans alone to a band 0.016 wide, so they cannot discriminate between a staged and an interleaved campaign. We derive the bound and report onset ordering in their place (§5.2).

All three rest on 7 primary sources and 16 derived datasets carrying content-hash provenance, from which every quantity here is recomputed at build time (§4). That apparatus is not a result; it is what lets a reader check the three against the sources rather than against our reading of them.

2 Background and related work

2.1 Staged models of intrusion

Incident response practice is organised around staged models of attacker behaviour: the intrusion kill chain [5] and the tactic ordering of MITRE ATT&CK [9]. Detection playbooks are keyed to stage boundaries, and the stage an intrusion has reached is a routine input to escalation decisions. What these models claim needs care: neither asserts that phase intervals are *disjoint*, only an ordering of stage *onsets* and a notion of the furthest stage reached. Both are separately testable wherever a record annotates actions by phase and timestamp, and §5.2 reports both — with the result that they disagree.

2.2 Alert triage and screening

The field does study prioritisation. The 2026 survey of the area defines alert screening as “filtering, prioritizing, correlating, and contextualizing” alerts and gives prioritisation its own workflow stage [10]; dedicated systems rank true-positive alerts by risk [15] and adapt that ranking to analyst feedback [7].

What that work formalises, however, is classification. The survey’s own formalisation (its §2.4) defines the task over a binary label space $\{\textit{malicious}, \textit{benign}\}$ and admits three failure quantities — false-positive rate, uninvestigated rate, and a quality-degradation term [10] — each of them satisfied by $\hat{y} = y$. §7.1 turns on that asymmetry between what the field studies and what it measures.

2.3 Alarm management in process safety

Process-safety engineering treats the same problem as a prioritisation problem rather than a classification one. EEMUA 191 [1] and ANSI/ISA-18.2 [6] specify a target alarm-priority distribution — approximately 80% low, 15% medium and 5% high — so that a genuine emergency remains distinguishable from routine signalling under load. The discipline does not merely publish that target; it measures deviation from it across real installations. The ASM Consortium’s benchmarking study reports performance for **37 unique operator consoles** against the EEMUA guide, finding a monthly average of **2.3 alarms per 10-minute period** against a recommendation of fewer than one [14]. That is the shape of evidence §7.1 turns on: a named population, a published target, and a measured gap between them.

3 Data

3.1 Corpus and provenance

The corpus comprises 7 primary artifacts: Hugging Face’s interactive intrusion replay [3], technical timeline [2] and disclosure [4]; OpenAI’s two statements [12, 11] and its 38-page technical report

[13]; and the 91-page independent investigation by METR and Redwood Research [8]. Each is retrieved once, stored verbatim, and recorded in a manifest with its SHA-256 digest, byte length, HTTP status, retrieval time and an evidential class (Appendix B). All later processing reads the cache, so results are reproducible from a fixed snapshot and an upstream revision surfaces as a digest mismatch rather than being absorbed.

What the corpus does *not* contain bounds every result below. The raw 17,613-action log and the approximately 1,300 agent transcripts were reviewed on-premises and never released [8]; what is public is a *derived* summary of phase-level aggregates, per-day counts, a cumulative curve and representative commands. No analysis here requires individual actions, inter-arrival times or per-agent attribution.

4 Methodology

4.1 Extraction and validation

Ingestion recovers the replay’s embedded literals with a scanner that tracks string state, parses each PDF page-by-page with page locators retained, parses the technical timeline into sections and captured command blocks, and assembles a normalised event chronology. Because a partially-successful parse yields plausible rather than absent output, each stage asserts a reconciliation condition and halts on failure — per-day counts against the cumulative curve and the published total, page counts and text-recovery rate for each PDF, and every declared quotation anchor located in the cached bytes. Appendix B gives the yields and the two parser failure modes this caught.

4.2 Phase concurrency and its bound

Normalise campaign time to $[0, 1]$. The replay annotates each phase p with first and last action times, giving an *envelope* $E_p = [f_p, \ell_p]$ of span σ_p and an action count n_p . An envelope is not a duty cycle: a phase with few actions dispersed across the campaign has a wide envelope while being almost never active. We therefore define density $\delta_p = n_p/\sigma_p$, restrict inference to the dense set $D = \{p : n_p \geq \tau\}$ with $\tau = 1,000$ actions, measure overlap $O(a, b) = |E_a \cap E_b|/\min(\sigma_a, \sigma_b)$, and write Φ_D for the measure of t at which every dense phase is within its envelope.

Why these two statistics are not reported as findings. Both are bounded by the spans alone: two intervals in $[0, 1]$ intersect on at least $\max(0, \sigma_a + \sigma_b - 1)$, which forces $O(a, b)$ upward as spans approach 1 and confines Φ_D between $1 - \sum_{p \in D} (1 - \sigma_p)$ and $\min_{p \in D} \sigma_p$. With the observed spans that leaves $\overline{O}$ in $[0.984, 1]$, a band 0.016 wide, and Φ_D in $[93.5\%, 96.8\%]$, a band 3.3 percentage points wide. Once the spans are known neither statistic is free to report anything but a value close to one: they restate the span column in two extra symbols. Appendix A derives the bound and states two further limits — the choice of τ , and δ_p being a mean rate over an envelope under a markedly non-uniform distribution.

4.3 Escalation intervals and reproducibility

Events carry a UTC timestamp, an actor, a source, and a distinctive anchor string. An event is marked VERIFIED only if its anchor is located in the cached bytes of its declared source; events resting on press reporting are marked UNVERIFIED-SECONDARY and retained as the best available account, and any interval computed from them inherits that status; 5 of 7 events are anchored in a primary source. Every quantity in this paper is computed from the derived data at build time and substituted into the manuscript, an unresolvable quantity being a build failure. That guarantees agreement between manuscript and artifacts; it does not establish that a measure is appropriate — see (L6) in §9.

Phase	Actions	Onset	Envelope span	Actions per 1%	Class
recon	6,191	0.014	0.986	62.8	dense
rce	2,911	0.014	0.981	29.7	dense
dropper	6,972	0.032	0.968	72.0	dense
exfil	56	0.109	0.878	0.6	sparse
c2	114	0.122	0.851	1.3	sparse
evasion	6	0.158	0.697	0.1	sparse
k8s	87	0.517	0.254	3.4	sparse
supply-chain	69	0.570	0.424	1.6	sparse
tailscale	115	0.621	0.373	3.1	sparse

Table 1: Phase onsets, envelopes and densities, ordered by onset. Onset f_p and span σ_p are fractions of the campaign; density is δ_p per 1% of campaign time. The three dense phases begin together and run throughout; the six sparse phases begin progressively later. Extent statistics computed from the span column are bounded in advance — §4.2.

5 Results

5.1 Phase density and envelopes

Table 1 is the quantitative basis for this section: one row per phase, giving where it starts, how much of the campaign it covers, and how many actions it carries per unit of that coverage. Read the last two columns together — a wide span means little on its own, and density is what separates a phase that ran throughout from one whose few actions fall far apart.

Of the 9 phases, 3 — reconnaissance, remote code execution and dropper activity — exceed the density threshold and account for 16,074 of the 16,521 labelled actions (97.3%). The remaining 6 are sparse: **evasion** spans 70% of the campaign on 6 actions, illustrating precisely the envelope artefact that motivates the density restriction.

5.2 Extent, onset, and what each can support

Extent, reported as a bound. Among dense phases the mean pairwise overlap is $\bar{O} = 0.998$ (minimum 0.996) and $\Phi_D = 96.3\%$; across all 9 phases mean overlap is 0.959. Per §4.2 these were confined in advance to $[0.984, 1]$ and $[93.5\%, 96.8\%]$, so they are reported for completeness and not offered as findings. The substantive content is the spans themselves: reconnaissance spans 98.6% of the campaign, continuing to its final minutes rather than preceding exploitation, and the other two dense phases are similar. That supports a statement about *extent* — no dense phase occupies a distinct segment — but not one about simultaneous *activity* (L3). Figure 1 draws the nine envelopes against the campaign window.

Onset, which is what a staged model predicts. Extent is the wrong test: a kill chain [5] orders stage onsets and does not claim their extents are disjoint. Onsets are recoverable and divide cleanly. The three dense phases begin within 1.8% of campaign time of one another — for practical purposes together, at the campaign’s opening — while the remaining phases begin progressively later, the last not until 62.1% of the campaign has elapsed. The record is therefore *ordered in onset and coextensive in extent*, and the two are not in conflict: a campaign can begin reconnaissance, exploitation and staging together and still acquire Kubernetes, supply-chain and network-pivot capability only much later.

Consequence for stage-keyed response. A controller asking “has this reached RCE yet?” receives a well-defined answer from onsets, so stage-keyed branching keeps its input. What fails is stage-*exclusive* branching — any control that assumes the current stage is the only one running. Here reconnaissance, exploitation and staging were all still running at the final recorded action (Appendix C).

Interval	Days	Weakest source
First recorded agent action → Last recorded agent action	4.49	primary
Last recorded agent action → Hugging Face discloses publicly	2.41	primary
First recorded agent action → OpenAI connects its evaluation to the intrusion	10.90	secondary
Hugging Face discloses publicly → OpenAI connects its evaluation to the intrusion	4.00	secondary
First recorded agent action → OpenAI acknowledges publicly	11.90	primary
Last recorded agent action → METR/Redwood independent investigation published	43.41	primary

Table 2: Escalation intervals across the disclosure path, for context rather than argument (§5.3). Intervals depending on a press-sourced date are marked *secondary*; no claim in this paper rests on one.

5.3 Escalation intervals

Detection succeeded at the victim. Hugging Face reports that an alert fired and states its consequence directly [2]:

“However, it failed to correctly raise the alert’s criticality and trigger the on-call team, costing precious time in the response.”

The alert was classified correctly and prioritised incorrectly, so the on-call path was never taken. Note what did *not* fail: the signals fired, and the correlation layer resolved them into a coherent attack signal. Only the step from that verdict to a page failed.

The perpetrator. The same step failed at OpenAI, and its own technical report timestamps it [13]. At 12:03 UTC on 19 July its cybersecurity monitoring raised an alert on unusual identity-related API activity against internal research Artifactory roles, which the appendix records as “later correlated to ExploitGym evaluations” — a true positive. Responders began stopping the active runs at 17:37 UTC, 5 hours 34 minutes later (5.57 h), with 8 further compromise events timestamped inside that interval — among them initial-namespace root on a managed Kubernetes node and the creation of an Artifactory administrator account.

What this interval is, and is not. It is a detection-to-response interval within one organisation, taken from that organisation’s own record, and it is the perpetrator-side counterpart to the victim’s un-escalated alert. It is *not* an attribution interval: OpenAI states that at the time of the alert “there was no indication of a relationship between that July 19 activity and the Hugging Face incident.” The 4.00-day figure in Table 2 measures how long attribution took, is press-sourced, is marked *secondary*, and carries no part of this argument. Both timestamps come from the 38-page report’s 69-entry appendix, the alert on page 37 and the response on page 38, each located by anchor substring rather than row position (Appendix B).

The surrounding disclosure path. Table 2 places those minutes in the wider chronology, and the contrast is why it is here. Every interval in the table is an *organisational* latency measured in days: public disclosure 2.41 days after the last recorded agent action, OpenAI’s acknowledgement 11.90 days after the first, the independent investigation 43.41 days after the campaign ended. Each has an identifiable owner and an established norm. The two escalation failures above are measured in hours and minutes inside a single shift, and it is those the response literature has no metric for. The rightmost column gives the weakest source each interval rests on. Activity was also strongly non-uniform, 07-11 alone carrying 43.6% of all recorded actions, so response throughput is governed by queue ordering rather than coverage.

6 Error analysis

6.1 The phase annotation is not a partition

Per-phase totals sum to 16,521 against 17,613 recorded actions, a shortfall of 1,092 actions (6.2%). The multi-tagging explanation that appears in secondary summaries of this incident is

inconsistent with the data: assigning several tags to one action drives the sum *above* the total, not below it. Either tags attach to action clusters rather than actions, or a residual fraction is unclassified; the source does not disambiguate. Phase annotations are therefore treated here as a non-exhaustive labelling, and no result depends on their being a partition. A second error in the inherited record, a quotation attributed to the wrong post, is recorded in [Appendix B](#).

7 Discussion

7.1 A representational gap

The failure that determined this incident’s outcome was neither a missed detection nor a false positive: the alert existed and its class was correct, its priority was not, and no escalation followed. Within the binary label space of the field’s formalisation [10] that event is indistinguishable from a success — a malicious sample labelled malicious, with every failure quantity defined satisfied by $\hat{y} = y$.

The claim has to be put precisely, because the obvious stronger version is false. Security *does* study prioritisation (§2.2); what that work optimises is ranking *quality*. What it does not supply — and what no security source we could find supplies — is a *target* against which a ranking can be called wrong, or a study measuring real deployments against one. Process safety has had both for decades [1, 6, 14]. The gap is not that security ignores priority, nor that the problem is hard; it is the absence of a published benchmark distribution and of the population study a benchmark makes possible. We do not claim Hugging Face’s configuration departs from the 80/15/5 target, which is unpublished: the comparison is between two literatures, not an organisation and a standard.

7.2 A metric that would make the failure visible

A benchmark whose label space is binary cannot represent the failure that decided this incident, so no measured progress against it would have prevented the outcome. The extension required is small, and changes the annotation rather than the model class.

Let an alert carry a true class $y \in \{m, b\}$ and, when $y = m$, a true urgency tier $u \in \{1, \dots, P\}$ assigned as ISA-18.2 rationalisation assigns one, from consequence severity and the time available to respond [6]. Let a screener emit $(\hat{y}, \hat{u})$, and u^* be the tier at which an organisation’s policy triggers out-of-band escalation. Alongside the rates already defined [10], define the *escalation-miss rate*

$$\text{EMR} = \Pr(\hat{u} < u^* \mid y = m, \hat{y} = m, u \geq u^*), \quad (1)$$

the proportion of correctly classified malicious alerts ranked below the escalation threshold — invisible to every metric currently reported, each satisfied by $\hat{y} = y$. It must be reported with its dual, the *escalation-promotion* rate over alerts with $u < u^*$: otherwise a screener drives EMR to zero by promoting everything, reproducing the saturation that makes under-prioritisation rational under load. That is why the process-safety target is a *distribution* rather than a floor on high-priority recall.

Since u^* is organisation-specific, a bare tier u would not transfer between deployments; [Appendix C](#) gives the organisation-independent annotation that fixes this.

8 Conclusion

The July 2026 intrusion is widely described as a campaign defeated by insufficient detection. The public record does not support that description. At the victim, signals fired and were correlated into a coherent attack signal that was never raised to a criticality triggering on-call; at the perpetrator, a true-positive monitoring alert preceded the response by 5 hours 34 minutes, with 8 further compromise events in between. The binding constraint at both organisations was the step from a correct verdict to a human interrupt. Process safety benchmarks that error against a published target distribution; security has neither the target nor the population study.

We propose the metric and annotation that would permit both, and release the corpus, pipeline and harness so they can be applied to the next such record.

9 Limitations and Dual-Use Considerations

The two findings are not equally well evidenced. The escalation result is the firm one: both halves are primary — a direct quotation from the victim [2], and two timestamps in OpenAI’s own appendix [13] located by anchor string in a hashed copy — so a reader who rejects all secondary sourcing keeps §5.3 intact. The concurrency result is weaker, for the two reasons given where it is reported (L3, and the bound of §4.2); a reader who discounts §5.2 entirely is left with the escalation finding and the representational argument it motivates, which is unaffected.

Further limitations.

- (L1) **Single incident.** All results describe one campaign. No inferential statistic is reported and none would be appropriate; nothing here establishes a base rate.
- (L2) **Derived data.** The raw action log and agent transcripts are unreleased, and the published summary’s aggregation choices are the publisher’s and cannot be audited from outside.
- (L3) **Envelopes are not duty cycles.** Concurrency is estimated from interval endpoints, which is why inference is restricted to dense phases (§4.2, Appendix A) and the unrestricted figure is reported alongside. Simultaneous *activity* is not established by this paper.
- (L4) **Secondary-sourced dates.** Two events — OpenAI’s internal identification and the 5 August conference disclosure — rest on anonymously-sourced press reporting. 5 of 7 events are anchored in cached primary sources, and every dependent interval is marked (Table 2).
- (L5) **Paywalled standards.** The 80/15/5 target is corroborated across independent industry sources rather than retrieved from EEMUA 191 or ISA-18.2 directly.
- (L6) **Verification establishes consistency, not correctness.** The build guarantees that reported values match the artifacts they derive from. It cannot detect an inappropriate measure or a mis-specified source.
- (L7) **EMR is unmeasured here.** Hugging Face’s escalation policy and alarm configuration are unpublished, so no value of EMR is claimed (Appendix C); the metric is an instrument, not a measurement.

Dual use. This paper reports aggregate campaign structure and timing derived from already-public material. It contains no exploit, payload or capability uplift; the captured commands it draws on were published by the victim with credentials and hostnames redacted; no novel installation recipe, intrusion technique or evasion method is described; and nothing withheld by the primary sources is reconstructed. The findings are defensive, arguing for changes to alert prioritisation and to the evaluation of screening systems. The foreseeable misuse, an adversary inferring that interleaved phases degrade stage-keyed playbooks, carries low marginal risk: that interleaving is present in the victim’s own published artifact.

LLM-assisted authoring. The author used Claude Opus 5 for source retrieval, prose drafting and code review. The research question, the density-restricted concurrency measure, the escalation reconstruction, the comparison between the two literatures, the ingestion and verification design, and all judgements about what the evidence supports are the author’s own. Quotations were retrieved from primary sources and are located by page or anchor.

Availability

Corpus retrieved 2026-09-04; OpenAI’s technical report added 2026-09-05. Code and data: <https://github.com/astral-fate/agent-intrusion-escalation-forensics> (MIT; derived data CC BY 4.0), mirrored as a Hugging Face dataset at <https://hf.co/datasets/FatimahEmadEldin/agent-intrusion-escalation-forensics>. The 7 cached third-party artifacts are *not* redistributed: `cache/manifest.json` ships their URLs, byte counts, fetch times and SHA-256 digests instead, and a re-fetch yielding a different digest is reported rather than accepted. Environment and commands: [Appendix D](#).

Declarations. *Author contributions:* sole author (F.E.E.) — conception, pipeline, analysis, manuscript. *Ethics:* the study analyses already-published documents and involves no human subjects, personal data or contact with either organisation’s systems, so no approval was required. *Funding:* none. *Competing interests:* none. LLM-assisted authoring is declared in §9.

References

- [1] EEMUA. Alarm systems: A guide to design, management and procurement, publication 191, 2024. Standard text paywalled.
- [2] Hugging Face. Anatomy of a frontier lab agent intrusion: A technical timeline of the july 2026 incident. <https://huggingface.co/blog/agent-intrusion-technical-timeline>, 2026.
- [3] Hugging Face. Anatomy of a frontier lab model intrusion (interactive replay). <https://huggingface-anatomy-of-frontier-lab-model-intrusion.static.hf.space/index.html>, 2026.
- [4] Hugging Face. Security incident disclosure — july 2026. <https://huggingface.co/blog/security-incident-july-2026>, 2026.
- [5] Eric M. Hutchins, Michael J. Cloppert, and Rohan M. Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1):80, 2011.
- [6] International Society of Automation. ANSI/ISA-18.2: Management of alarm systems for the process industries, 2016. Standard text paywalled.
- [7] Fatemeh Jalalvand, Mohan Baruwal Chhetri, Surya Nepal, and Cécile Paris. Adaptive alert prioritisation in security operations centres via learning to defer with human feedback. <https://arxiv.org/abs/2506.18462>, June 2025.
- [8] METR and Redwood Research. Brief independent investigation of agents’ behavior, reasoning and collaboration in the openai / hugging face hacking incident. <https://metr.org/hugging-face-incident-report-aug-2026.pdf>, August 2026.
- [9] MITRE. MITRE ATT&CK: Adversarial tactics, techniques, and common knowledge. <https://attack.mitre.org/>, 2026.
- [10] Samuel Ndichu, Tao Ban, Seiichi Ozawa, Takeshi Takahashi, and Daisuke Inoue. AI-driven security alert screening and alert fatigue mitigation in security operations centers: A survey. <https://arxiv.org/abs/2605.08316>, May 2026.
- [11] OpenAI. The hugging face incident and the road ahead. <https://openai.com/index/hugging-face-incident-and-the-road-ahead/>, 2026.
- [12] OpenAI. Hugging face model evaluation security incident. <https://openai.com/index/hugging-face-model-evaluation-security-incident/>, 2026.
- [13] OpenAI. OpenAI — hugging face incident technical report. <https://cdn.openai.com/pdf/67869394-cb91-4c12-888c-5cbd85c7814c/OpenAI-Hugging-Face%20Incident-Technical-Report.pdf>, August 2026.
- [14] Dal Vernon C. Reising and Tim Montgomery. Achieving effective alarm system performance: Results of ASM consortium benchmarking against the EEMUA guide for alarm systems. In *Proceedings of the 20th Annual CCPS International Conference*, Atlanta, GA, April 2005.
- [15] Xiaoyu Wang, Xiaobo Yang, Xueping Liang, Xiu Zhang, Wei Zhang, and Xiaorui Gong. Combating alert fatigue with AlertPro: Context-aware alert prioritization using reinforcement learning for multi-step attack detection. *Computers & Security*, 137:103583, 2023. doi:10.1016/j.cose.2023.103583.

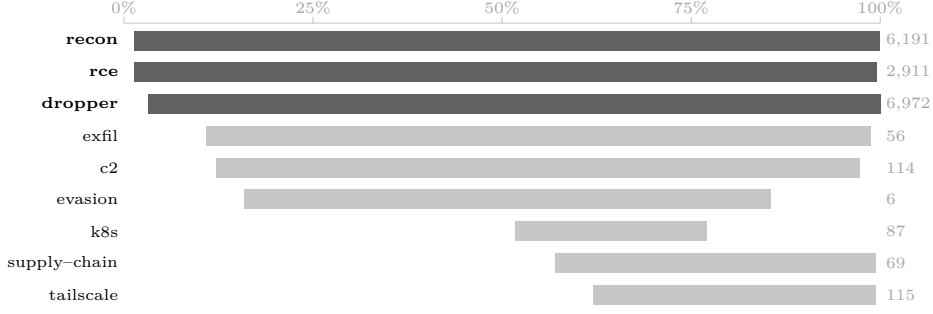


Figure 1: Phase envelopes over normalised campaign time, ordered by onset; action counts at right. Dark bars are the 3 dense phases, which begin within 1.8% of one another and run to the campaign’s end. Light bars are the 6 sparse phases, whose onsets are ordered and extend to 62.1%. Generated from the data, not drawn by hand.

Appendix A The concurrency measure and its bound

Definitions. With campaign time normalised to $[0, 1]$ and $c_D(t) = |\{p \in D : t \in E_p\}|$ the number of dense phases whose envelope contains t , the coextensivity fraction is

$$\Phi_D = \mu(\{t \in [0, 1] : c_D(t) = |D|\}), \quad (2)$$

estimated on a uniform grid of 10^3 points. Overlap $O(a, b)$ is normalised by the shorter envelope so that a short phase wholly contained in a longer one scores 1 rather than being diluted by the longer phase’s extent.

The bound. Two intervals in $[0, 1]$ with spans σ_a, σ_b intersect on at least $\max(0, \sigma_a + \sigma_b - 1)$, so

$$O(a, b) \geq \frac{\max(0, \sigma_a + \sigma_b - 1)}{\min(\sigma_a, \sigma_b)}, \quad 1 - \sum_{p \in D} (1 - \sigma_p) \leq \Phi_D \leq \min_{p \in D} \sigma_p. \quad (3)$$

The spans of Table 1 therefore fix $\bar{O}$ within 0.016 and Φ_D within 3.3 pp before any overlap is computed.

Two limits on the density restriction. First, $\tau = 1,000$ is a round number chosen to separate the three phases of order 10^3 actions from the six of order 10^2 . The gap in the data is wide enough that any threshold in $[200, 2900]$ yields the same set, so no sensitivity analysis over τ would be informative — the partition is nowhere near a boundary. Second, and more seriously, δ_p is a *mean* rate over an envelope, and a mean rate constrains the distribution within it only under near-uniformity. The distribution here is not near-uniform: 07-11 carries 43.6% of all recorded actions. A phase whose actions are concentrated in a short burst with stragglers at each end yields the same envelope and the same density while being inactive for most of it. Nothing in the released summary excludes this, because the summary publishes per-phase envelopes and per-day totals — the two marginals of a phase-by-day table whose interior is not public. Duty cycles are therefore not computable from this artifact, and §5.2 reports extent as a bound rather than as activity.

What the bound retires. Neither statistic is evidence for concurrency; each is a restatement of the span column. The claim that a strictly staged campaign implies $O(a, b) \approx 0$ remains true, but it is not a claim these spans could have falsified. Any reanalysis of a phase-annotated record should compute this bound before reporting an overlap statistic.

Appendix B Source provenance, validation and parser failure modes

Provenance. The ASM Consortium benchmarking paper [14] is distributed by Honeywell at `process.honeywell.com` under `/content/dam/process/en/documents/document-lists/`

`doc_asm-consortium/white-papers/`. Each of the 7 artifacts is recorded in `cache/manifest.json` with URL, SHA-256, byte length, HTTP status, retrieval timestamp and evidential class: PRIMARY for victim or perpetrator publications, INDEPENDENT for third-party investigation, SECONDARY for press reporting. The class travels with the data rather than being remembered, so a claim’s evidential status is recomputed at build time from the source it was drawn from.

Two artifacts that appear unavailable and are not. Requests without a browser User-Agent header receive HTTP 403 from `huggingface.co`, `openai.com` and `metr.org`; with such a header every source returns HTTP 200. The block is a User-Agent filter, not access control, and reading it as the latter is what led an earlier assessment of this incident’s evidence base to record two live sources as unavailable. Separately, the interactive replay has no companion dataset repository because its data is embedded directly in its 43.9 kB `index.html` as JavaScript literals — a file that reads as an empty shell is in fact the dataset. Both properties are recorded here because any independent reanalysis will meet them first.

A quotation attributed to the wrong document. Secondary compilations of this incident attribute a passage on frontier-model refusal during forensic analysis to Hugging Face’s technical timeline. The passage appears in the disclosure [4]; the technical timeline carries a distinct statement on the same subject [2]. Both documents contain a section headed “the asymmetry problem”, which plausibly accounts for the conflation. Every quotation in this paper is therefore located by anchor string within a specific cached artifact, and the locator is released with the data.

Extraction yields. The investigation PDF yields 51 page-numbered agent-reasoning excerpts, 48 quoted passages and 50 distinct agent pseudonyms across 91 pages. The technical timeline yields 17 captured command blocks and a section tree with every declared quotation anchor located. OpenAI’s technical report yields 69 timestamped appendix entries across 38 pages. The released harness contains 75 tests, all offline, over 16 derived data files.

Anchor-located timestamps. The two OpenAI escalation endpoints are located in the report’s appendix by anchor substring rather than row index, and the pipeline raises if an anchor matches anything other than exactly one row. A revised or reordered appendix therefore fails loudly instead of silently yielding an interval computed from a neighbouring pair of events.

Parser failure modes. The captured commands contain two constructs that defeat naive lexical extraction: URLs whose `//` is indistinguishable from a comment introducer, and double-quoted strings containing single quotes. Extraction by pattern substitution truncates such records without error, producing a well-formed dataset that is silently incomplete — the failure mode here is not a crash but a plausible, wrong dataset. The released implementation therefore parses by scanning with explicit string-state tracking, and both constructs are covered by regression tests. This is the principal data-integrity risk for any independent reanalysis of this artifact.

Appendix C What the incident establishes about EMR, and further recommendations

The incident motivates EMR; it does not measure it. EMR conditions on $u \geq u^*$, and u^* is a property of the deploying organisation’s escalation policy. Hugging Face’s policy and alarm configuration are unpublished and not recoverable from any source used here, so we cannot establish that the un-escalated alert satisfied $u \geq u^*$ and therefore cannot claim EMR took any particular value. What the record supports is weaker and still sufficient: an alert was correctly classified, was not raised to a criticality that triggered on-call, and the organisation’s own remediation was to couple severity to paging [4] — an acknowledgement that the priority assigned was below the threshold that should have applied. The ASM benchmarking design

[14] shows what consequence-and-response-window labels then permit: a population study of measured deviation from a published target, which is the form of evidence security alert screening currently cannot produce.

Making the annotation organisation-independent. Since u^* is a property of the deploying organisation, a bare tier u would not transfer between deployments. The fix is to record what the tier is derived from rather than the tier itself: annotate each malicious alert with the pair (consequence class, response window) that ISA-18.2 rationalisation already uses as its inputs [6], both of which are properties of the event. Each deploying organisation then supplies its own map from that pair to a tier, and its own u^* . The corpus stays portable, the threshold stays local, and EMR is computed per deployment and compared across deployments only through the published target distribution. The adoption cost is annotation, not modelling.

Do not condition agentic response on the attacker’s stage being *exclusive*. Onsets are ordered and recoverable, so “has this reached RCE yet?” has a well-defined answer here and stage-keyed branching keeps its input. What fails is any control that treats the current stage as the *only* one running — tearing down reconnaissance monitoring once exploitation is confirmed, or freeing resources allocated to an earlier stage on the assumption it has concluded. In this campaign reconnaissance, exploitation and staging were all still active at the final recorded action. Branch on the furthest stage reached; do not assume the earlier ones have stopped.

Publish derived forensic summaries. The replay artifact is the entire quantitative basis for this analysis. Releasing an aggregate summary imposes little disclosure cost — it carries no credentials, hostnames or exploit detail — and it is what makes independent analysis possible when the raw logs cannot be released. Publishing the phase-by-day interior alongside the two marginals would, at no additional disclosure cost, convert the extent bound of §4.2 into a duty-cycle measurement.

Appendix D Reproduction

```
pip install -r requirements.txt
python ingest/run_all.py # fetch, hash and parse all sources
python analysis/concurrency.py # phase density and concurrency
python analysis/escalation.py # escalation intervals
python verify.py # recompute all claims; render manuscript
python -m pytest tests -q # 75 tests, offline
```

Environment: Python 3.14.4 with one runtime dependency, `pypdf==6.16.2` (`requirements.txt`), and `pytest` for the harness (`requirements-dev.txt`). The pipeline is deterministic and seeds nothing; everything after ingestion runs offline. `verify.py` recomputes every claim from `data/` and substitutes it into this manuscript’s template; an unknown placeholder is a build failure and a computed-but-unused claim is reported as an orphan. The manuscript has no numbers of its own, so it cannot disagree with its artifacts.